

Actividad | 2# | Auditoría Informática

Deserialización Insegura

Ingeniería en Desarrollo de Software



TUTOR: Jessica Hernández Romero

ALUMNO: Casandra Montserrat Ortiz Cortes G-1

FECHA: 14/05/2026

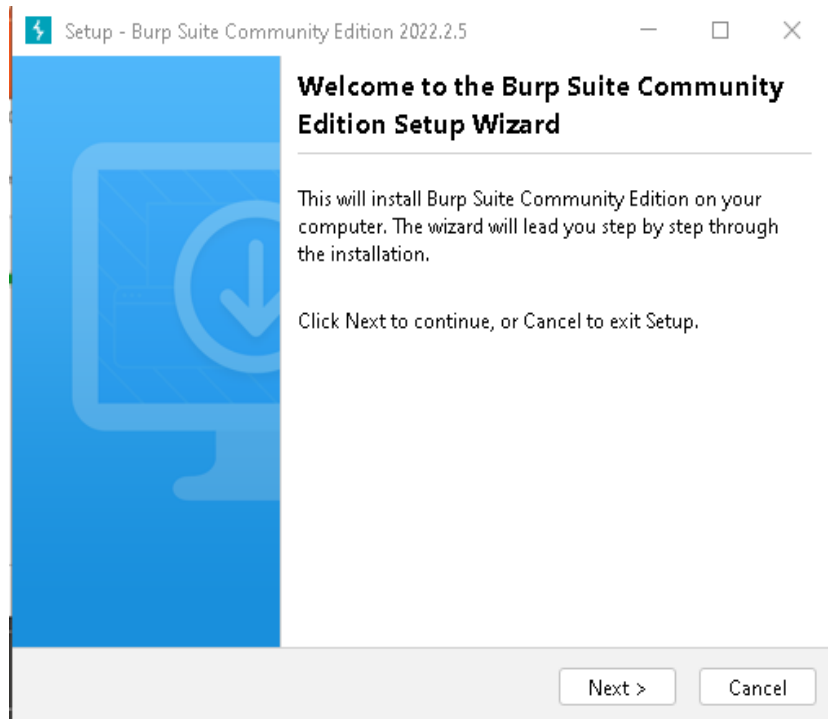
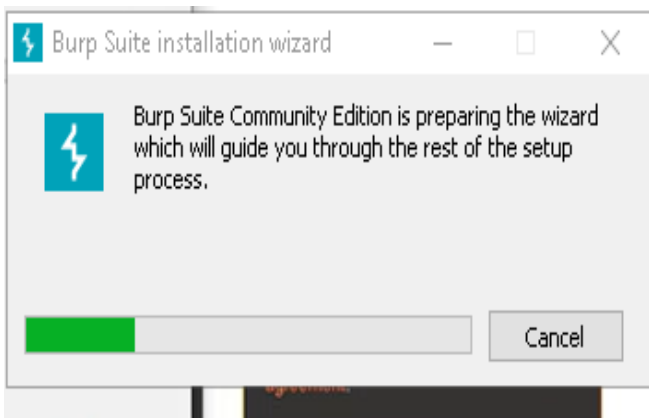
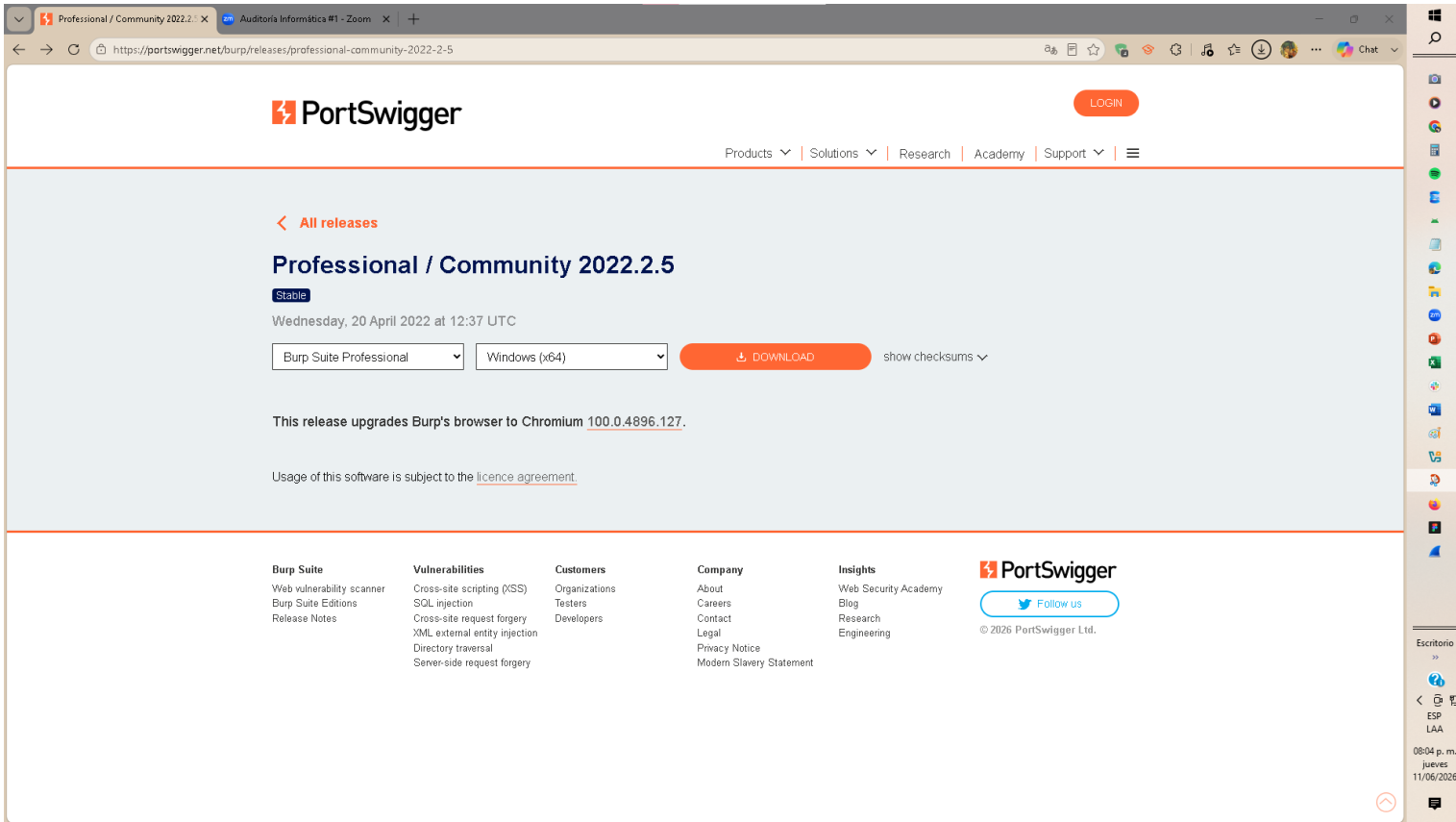
Índice

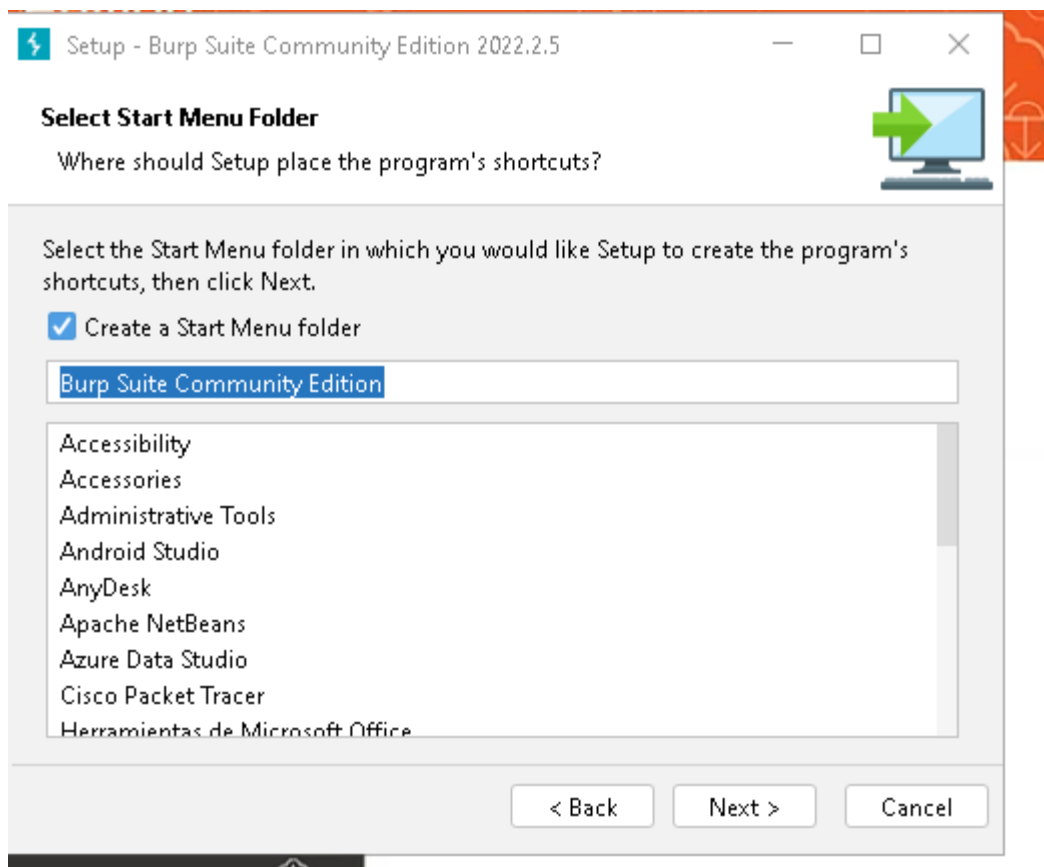
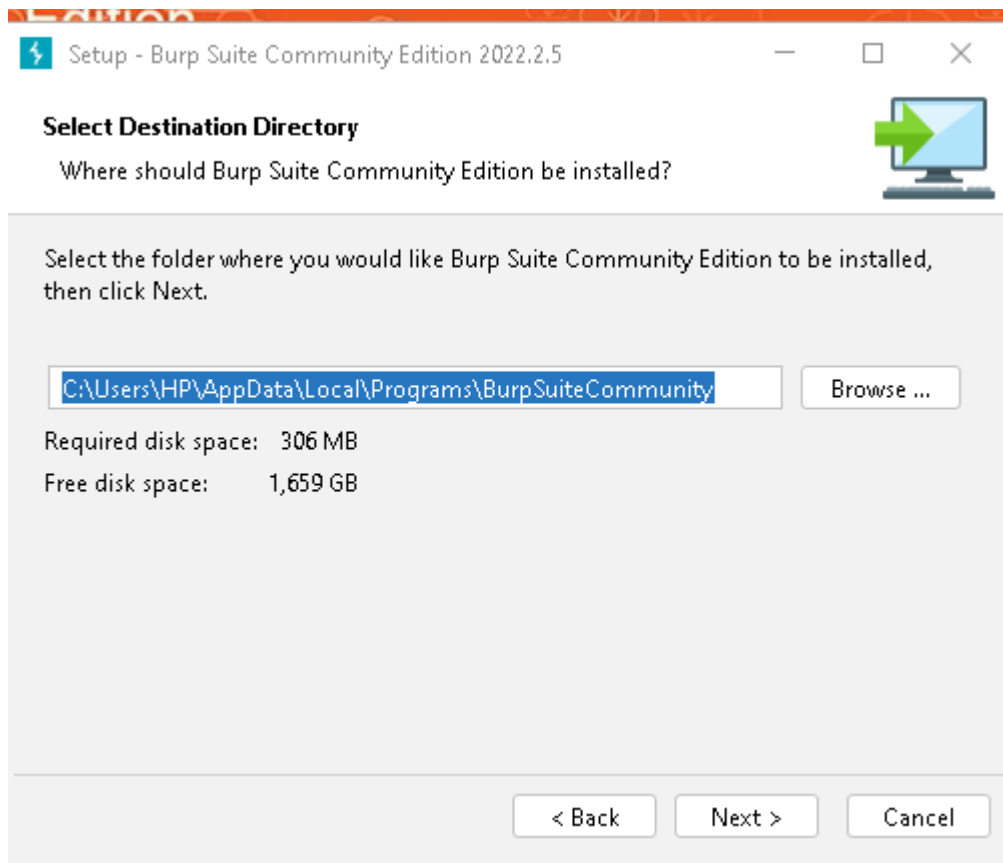
Desarrollo.....1

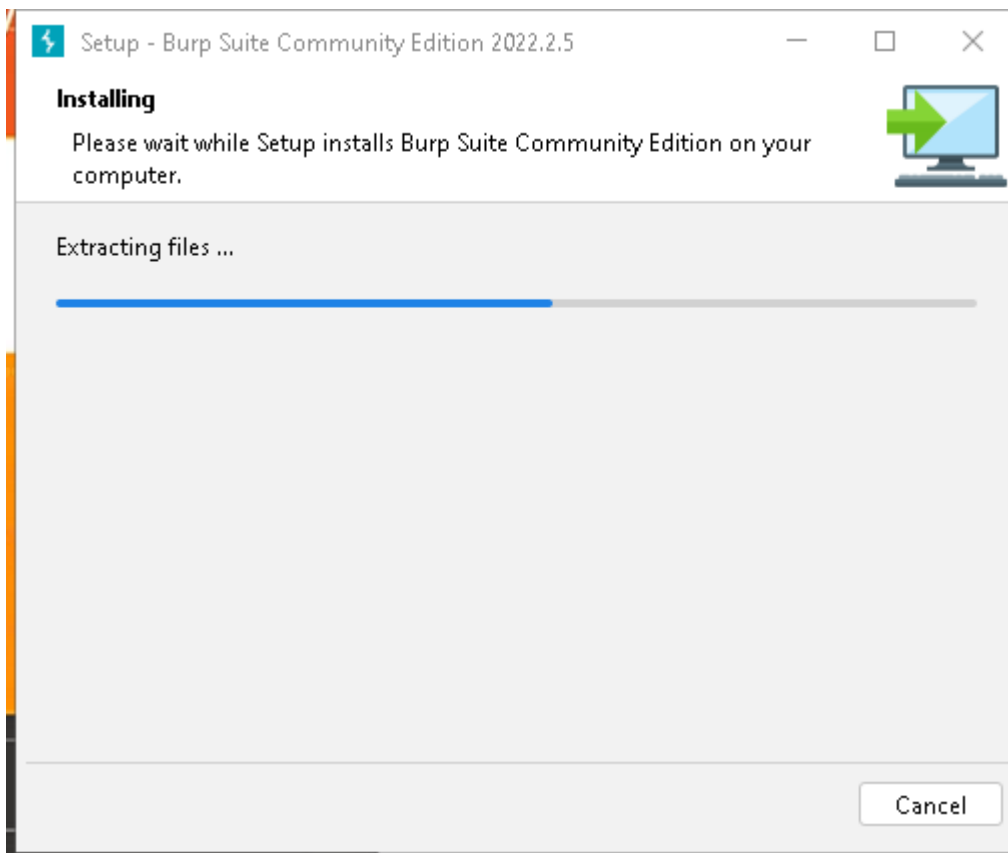
- Ataque al sitio

DESARROLLO

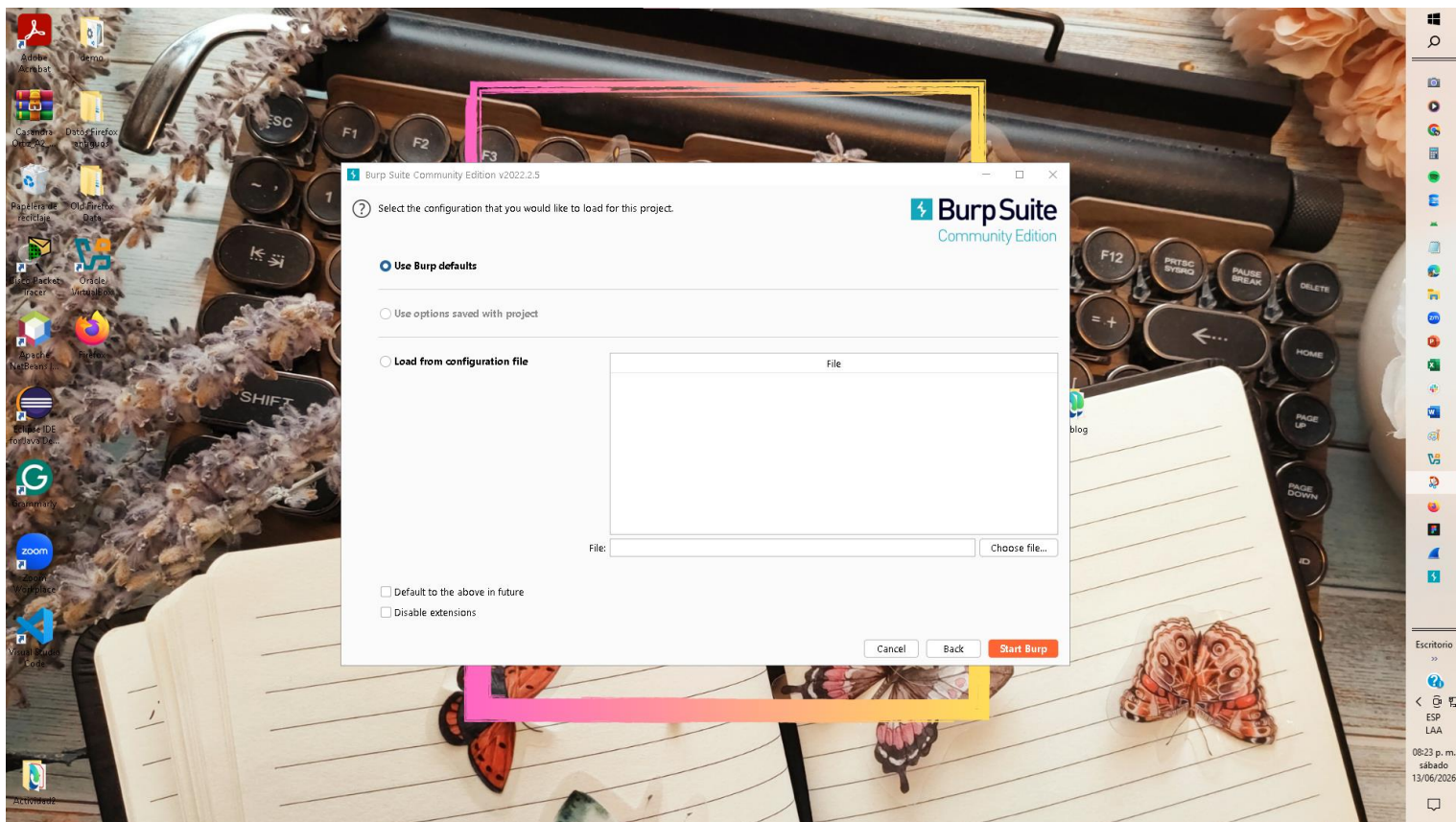
Ataque al sitio



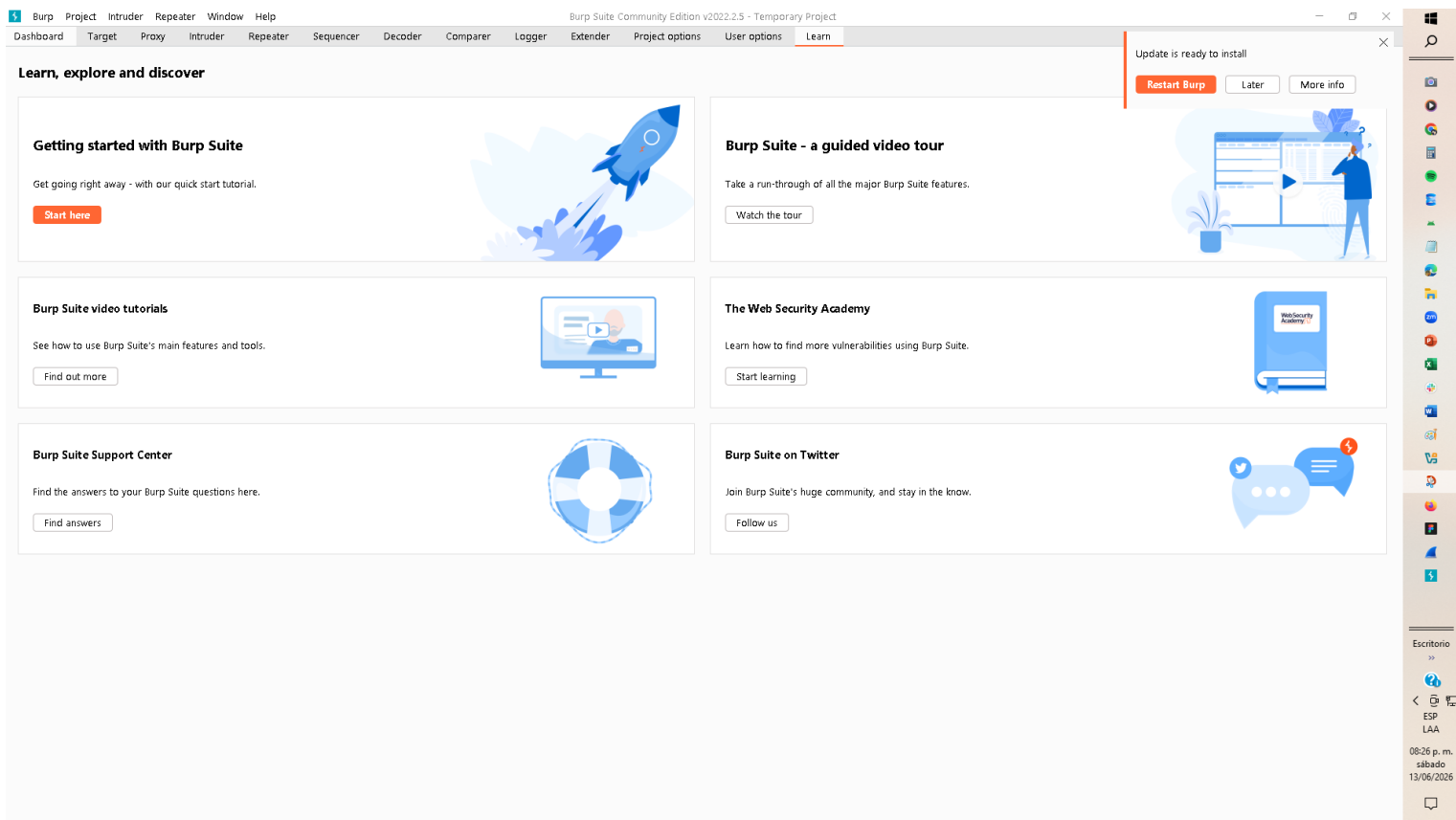




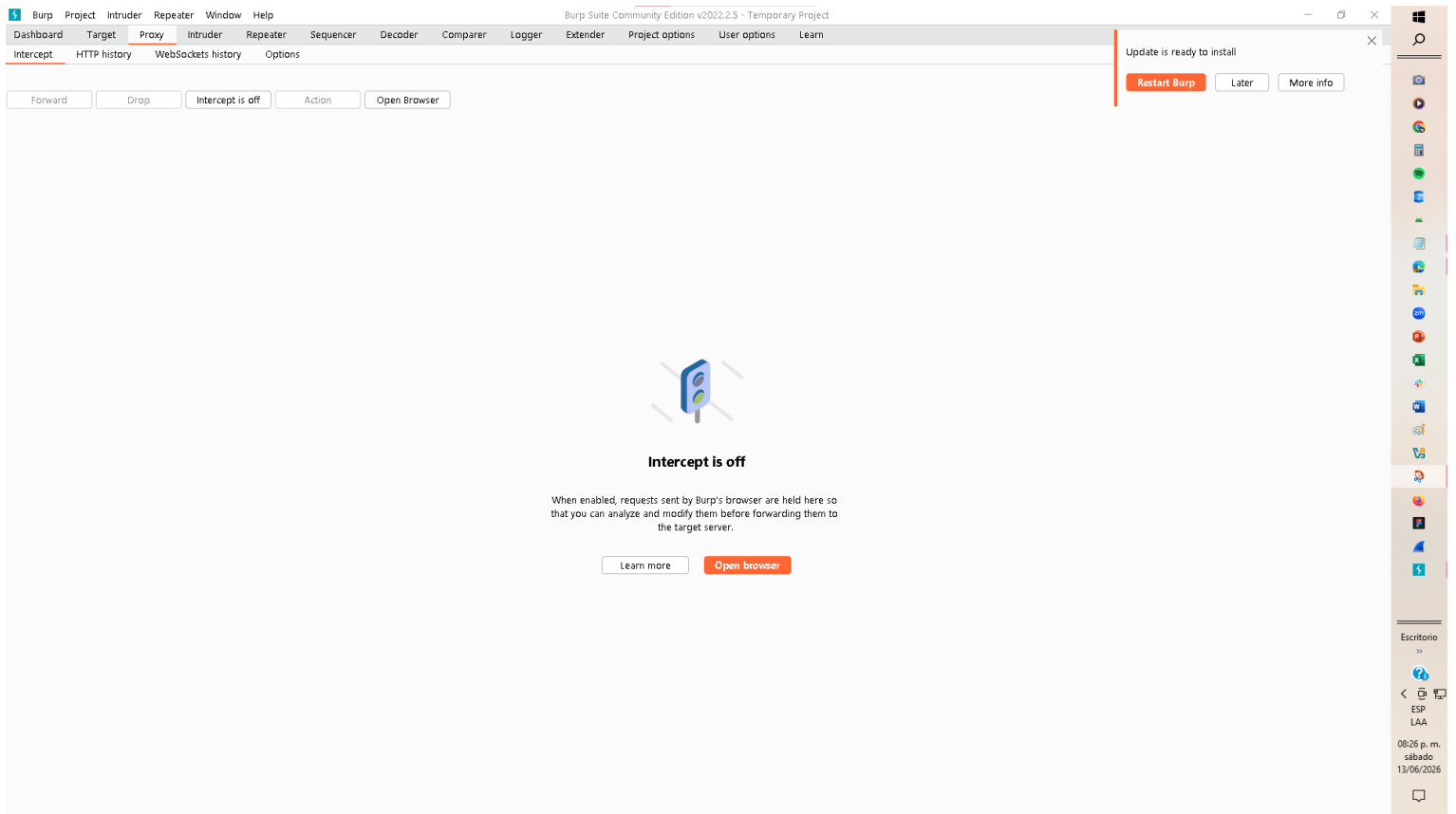
Se descargó Burp Suite Community Edition desde la página oficial para realizar la actividad.



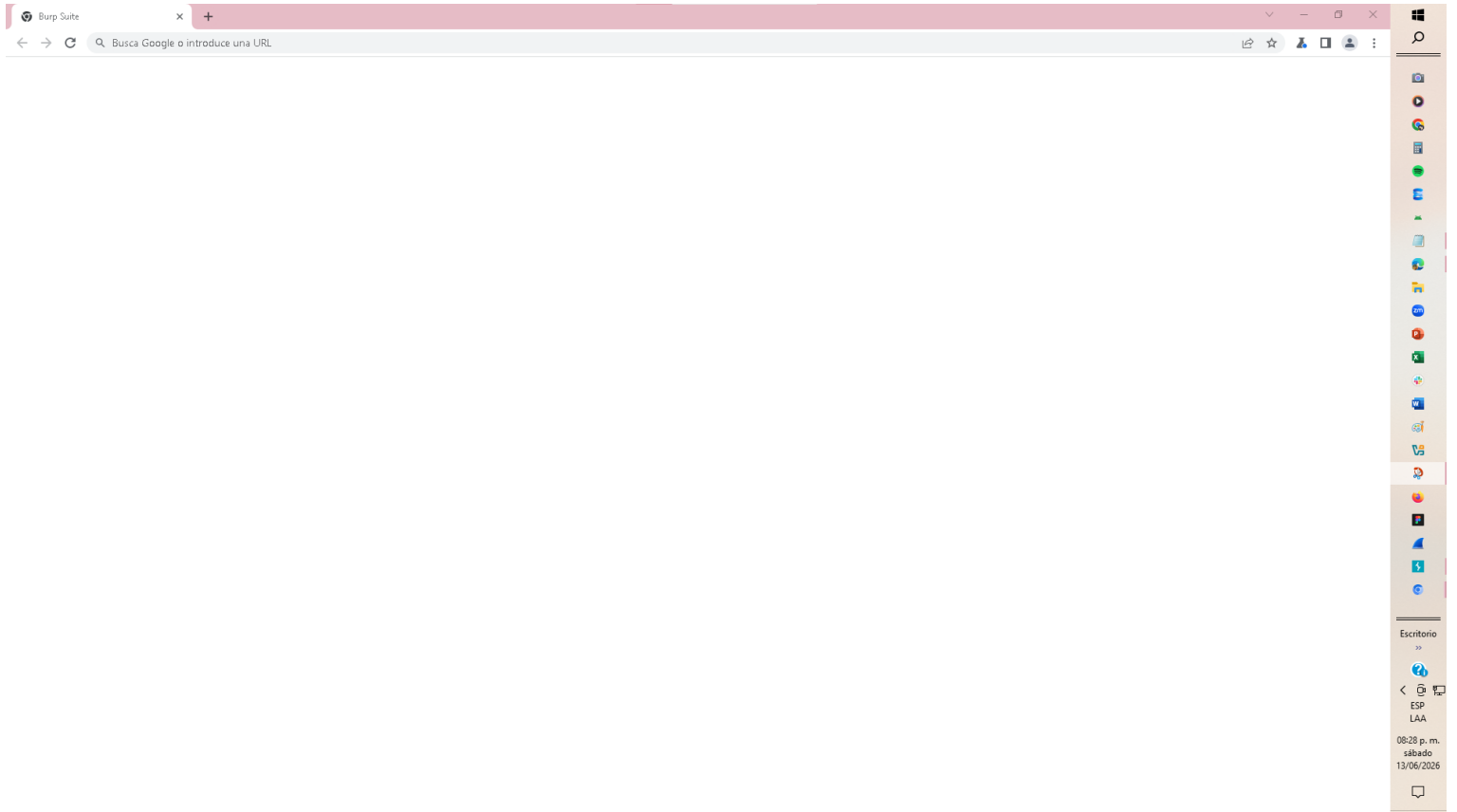
Se creó un proyecto temporal en Burp Suite para trabajar durante la actividad



Se mostró la pantalla principal de Burp Suite con las herramientas disponibles para analizar tráfico web.



Se revisó la sección Proxy para observar y capturar las peticiones enviadas por el navegador.



Se abrió el navegador integrado de Burp Suite para acceder al laboratorio de práctica.

Lab: Modifying serialized objects

PortSwigger

Products | Solutions | Research | Academy | Support

Dashboard | Learning paths | Latest topics | All content | Hall of Fame | Get started | Get certified

Web Security Academy > Insecure deserialization > Exploiting > Lab

Lab: Modifying serialized objects

APPRENTICE

This lab uses a serialization-based session mechanism and is vulnerable to privilege escalation as a result. To solve the lab, edit the serialized object in the session cookie to exploit this vulnerability and gain administrative privileges. Then, delete the user `carlos`.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

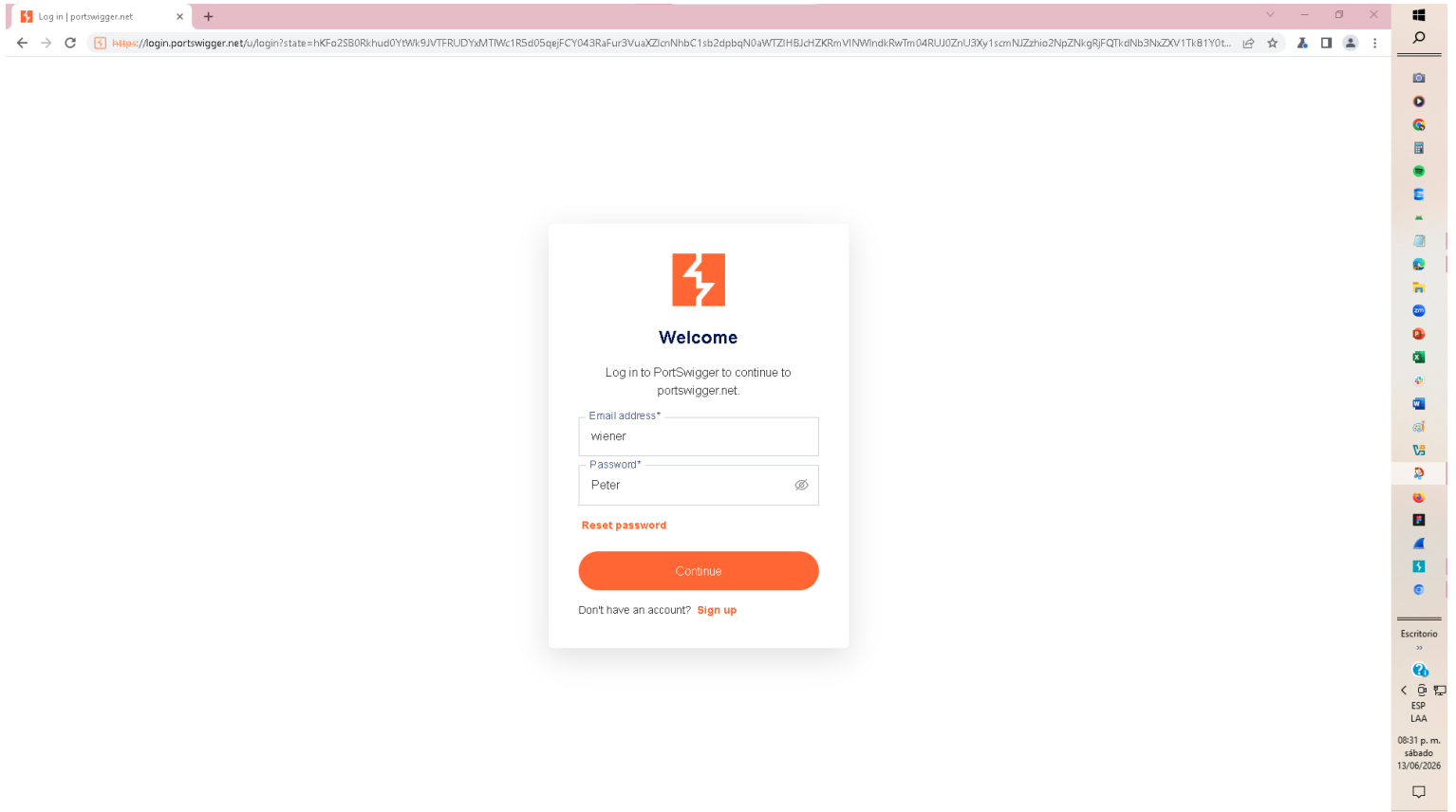
Solution

Community solutions

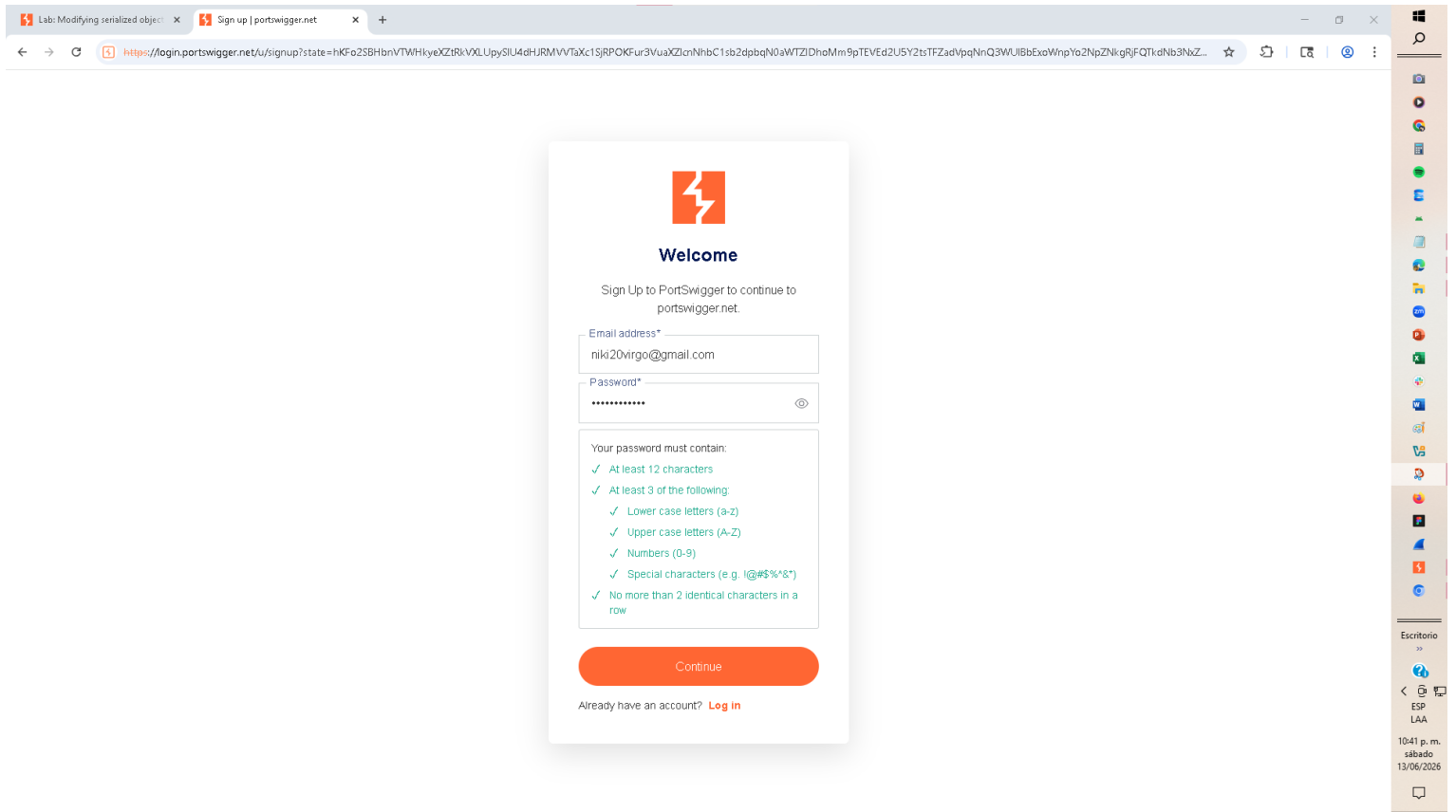
Register for free to track your learning progress

- Practise exploiting vulnerabilities on realistic targets.
- Record your progression from Apprentice to Expert.

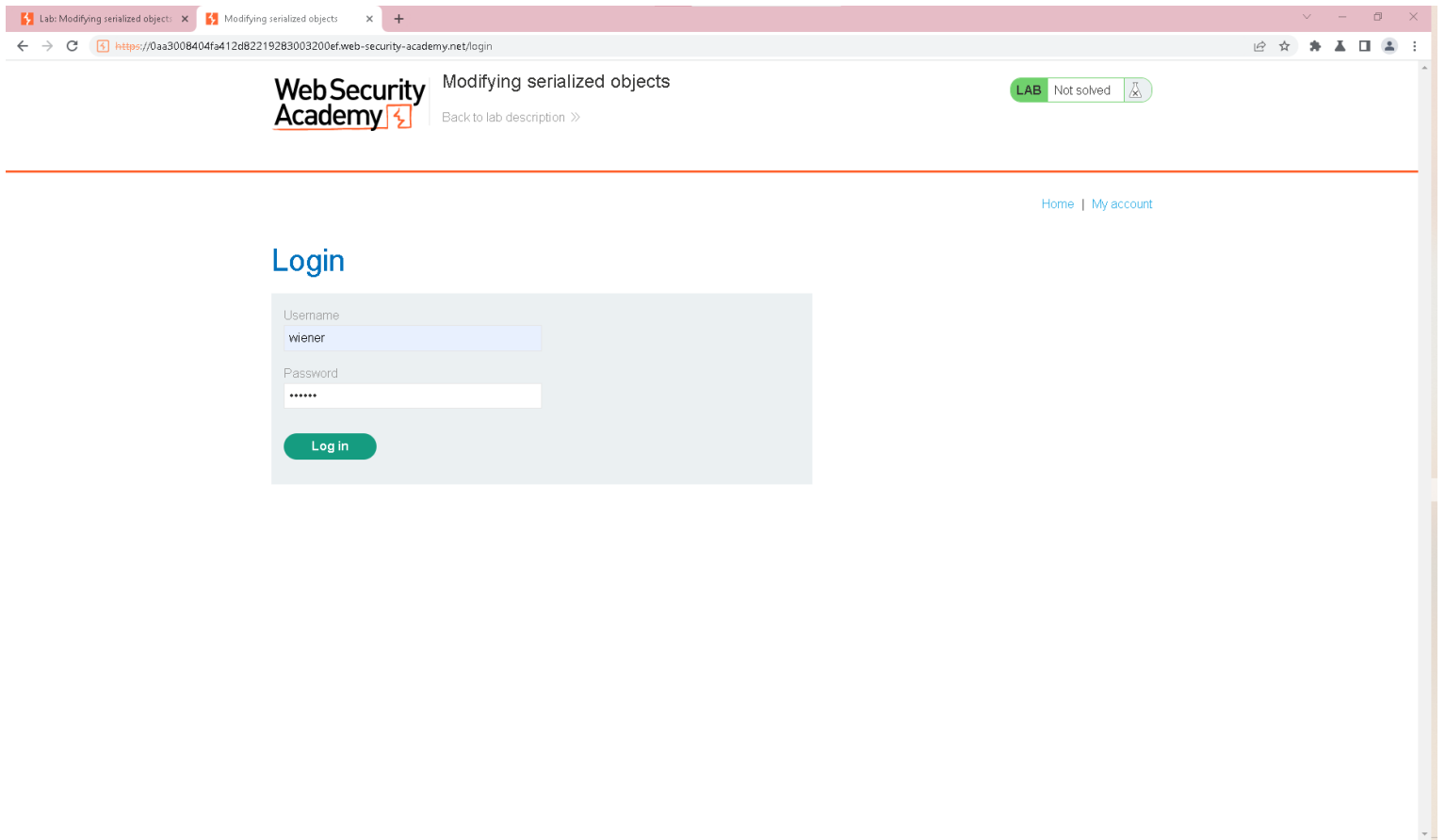
Se ingresó al laboratorio "Modifying serialized objects" de PortSwigger para realizar la actividad.



Se mostró la pantalla de inicio de sesión de PortSwigger para acceder al laboratorio.



Se completó el formulario de registro para crear una cuenta y continuar con la práctica



Se inició sesión con el usuario proporcionado por el laboratorio para acceder al sitio de prueba

Lab: Modifying serialized objects x Modifying serialized objects x +

← → ↻ <https://0aa3008404fa412d82219283003200ef.web-security-academy.net> ☆ ⚙️ 👤 ⋮

WebSecurity Academy

Modifying serialized objects

LAB Not solved

[Back to lab description](#) »

[Home](#) | [My account](#)

WE LIKE TO SHOP 



Paint a rainbow
★★★★☆ \$37.76
[View details](#)



Weird Crushes Game
★★★★☆ \$6.25
[View details](#)



Portable Hat
★★★☆☆ \$92.44
[View details](#)



Caution Sign
★★★★★ \$50.19
[View details](#)



Conversation Controlling Lemon
★★★★☆ \$65.62



Balance Beams
★★★☆☆ \$67.33



WTF? - The adult party game
★★★★☆ \$39.14



The Trolley-ON
★★★★☆ \$88.76

Se accedió a la tienda virtual del laboratorio para analizar su funcionamiento y las solicitudes generadas.

Burp Suite Community Edition v2022.2.5 - Temporary Project

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender Project options User options Learn

Intercept HTTP history WebSockets history Options

Filter: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status	Length	MIME type	Extension	Title	Comment	TLS	IP	Cookies	Time	Listener port
836	https://0aa3008404fa412d8221...	GET	/resources/images/shop.svg			200	7258	XML	svg			✓	79.125.84.16		22:02:30 13 J...	8080
861	https://0aa3008404fa412d8221...	GET	/resources/labheader/images/logoAc...			200	8952	XML	svg			✓	79.125.84.16		22:02:30 13 J...	8080
862	https://0aa3008404fa412d8221...	GET	/resources/labheader/images/ps-lab...			200	942	XML	svg			✓	79.125.84.16		22:02:30 13 J...	8080
863	https://0aa3008404fa412d8221...	GET	/academyLabHeader			101	147					✓	79.125.84.16		22:02:30 13 J...	8080
865	https://0aa3008404fa412d8221...	GET	/my-account			302	86					✓	79.125.84.16		22:02:30 13 J...	8080
866	https://0aa3008404fa412d8221...	GET	/login			200	3252	HTML		Modifying serialized obj...		✓	79.125.84.16		22:03:44 13 J...	8080
868	https://0aa3008404fa412d8221...	GET	/academyLabHeader			101	147					✓	79.125.84.16		22:03:46 13 J...	8080
869	https://0aa3008404fa412d8221...	POST	/login			302	238					✓	79.125.84.16	session=Tzo0OjV...	22:05:21 13 J...	8080
870	https://0aa3008404fa412d8221...	GET	/my-account?id=wiener	https://0aa3008404fa412d8221.demy.net/my-account?id=wiener						Modifying serialized obj...		✓	79.125.84.16		22:05:22 13 J...	8080
872	https://0aa3008404fa412d8221...	GET	/academyLabHeader	Add to scope						Modifying serialized obj...		✓	79.125.84.16		22:05:23 13 J...	8080
873	https://0aa3008404fa412d8221...	GET	/my-account?id=wiener									✓	79.125.84.16		22:10:08 13 J...	8080
876	https://0aa3008404fa412d8221...	GET	/academyLabHeader									✓	79.125.84.16		22:10:10 13 J...	8080

Request

1 GET /my-account?id=wiener HTTP/2

2 Host: 0aa3008404fa412d82219283003200ef.web-security

3 Cookie: session=Tzo0OjVlc2VyejVlbnVzZm9uTWllIjtzOjY6IndpZW50

4 Cache-Control: max-age=0

5 Upgrade-Insecure-Requests: 1

6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; Gecko) Chrome/100.0.4896.127 Safari/537.36

7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

8 Sec-Fetch-Site: same-origin

9 Sec-Fetch-Mode: navigate

10 Sec-Fetch-User: ?1

11 Sec-Fetch-Dest: document

12 Sec-Ch-Ua: "(Not A;Brand";v="8", "Chromium";v="100"

13 Sec-Ch-Ua-Mobile: ?0

14 Sec-Ch-Ua-Platform: "Windows"

15 Referer: https://0aa3008404fa412d82219283003200ef.w

16 Accept-Encoding: gzip, deflate

17 Accept-Language: es-ES,es;q=0.9

18

19

20

21

22

23

24

25

26

27

28

29

30

31

32

33

34

35

36

37

38

39

40

41

42

43

44

45

46

47

48

49

50

51

52

53

54

55

56

57

58

59

60

61

62

63

64

65

66

67

68

69

70

71

72

73

74

75

76

77

78

79

80

81

82

83

84

85

86

87

88

89

90

91

92

93

94

95

96

97

98

99

100

101

102

103

104

105

106

107

108

109

110

111

112

113

114

115

116

117

118

119

120

121

122

123

124

125

126

127

128

129

130

131

132

133

134

135

136

137

138

139

140

141

142

143

144

145

146

147

148

149

150

151

152

153

154

155

156

157

158

159

160

161

162

163

164

165

166

167

168

169

170

171

172

173

174

175

176

177

178

179

180

181

182

183

184

185

186

187

188

189

190

191

192

193

194

195

196

197

198

199

200

201

202

203

204

205

206

207

208

209

210

211

212

213

214

215

216

217

218

219

220

221

222

223

224

225

226

227

228

229

230

231

232

233

234

235

236

237

238

239

240

241

242

243

244

245

246

247

248

249

250

251

252

253

254

255

256

257

258

259

260

261

262

263

264

265

266

267

268

269

270

271

272

273

274

275

276

277

278

279

280

281

282

283

284

285

286

287

288

289

290

291

292

293

294

295

296

297

298

299

300

301

302

303

304

305

306

307

308

309

310

311

312

313

314

315

316

317

318

319

320

321

322

323

324

325

326

327

328

329

330

331

332

333

334

335

336

337

338

339

340

341

342

343

344

345

346

347

348

349

350

351

352

353

354

355

356

357

358

359

360

361

362

363

364

365

366

367

368

369

370

371

372

373

374

375

376

377

378

379

380

381

382

383

384

385

386

387

388

389

390

391

392

393

394

395

396

397

398

399

400

401

402

403

404

405

406

407

408

409

410

411

412

413

414

415

416

417

418

419

420

421

422

423

424

425

426

427

428

429

430

431

432

433

434

435

436

437

438

439

440

441

442

443

444

445

446

447

448

449

450

451

452

453

454

455

456

457

458

459

460

461

462

463

464

465

466

467

468

469

470

471

472

473

474

475

476

477

478

479

480

481

482

483

484

485

486

487

488

489

490

491

492

493

494

495

496

497

498

499

500

501

502

503

504

505

506

507

508

509

510

511

512

513

514

515

516

517

518

519

520

521

522

523

524

525

526

527

528

529

530

531

532

533

534

535

536

537

538

539

540

541

542

543

544

545

546

547

548

549

550

551

552

553

554

555

556

557

558

559

560

561

562

563

564

565

566

567

568

569

570

571

572

573

574

575

576

577

578

579

580

581

582

583

584

585

586

587

588

589

590

591

592

593

594

595

596

597

598

599

600

601

602

603

604

605

606

607

608

609

610

611

612

613

614

615

616

617

618

619

620

621

622

623

624

625

626

627

628

629

630

631

632

633

634

635

636

637

638

639

640

641

642

643

644

645

646

647

648

649

650

651

652

653

654

655

656

657

658

659

660

661

662

663

664

665

666

667

668

669

670

671

672

673

674

675

676

677

678

679

680

681

682

683

684

685

686

687

688

689

690

691

692

693

694

695

696

697

698

699

700

701

702

703

704

705

706

707

708

709

710

711

712

713

714

715

716

717

718

719

720

721

722

723

724

725

726

727

728

729

730

731

732

733

734

735

736

737

738

739

740

741

742

743

744

745

746

747

748

749

750

751

752

753

754

755

756

757

758

759

760

761

762

763

764

765

766

767

768

769

770

771

772

773

774

775

776

777

778

779

780

781

782

783

784

785

786

787

788

789

790

791

792

793

794

795

796

797

798

799

800

801

802

803

804

805

806

807

808

809

810

811

812

813

814

815

816

817

818

819

820

821

822

823

824

825

826

827

828

829

830

831

832

833

834

835

836

837

838

839

840

841

842

843

844

845

846

847

848

849

850

851

852

853

854

855

856

857

858

859

860

861

862

863

864

865

866

867

868

869

870

871

872

873

874

875

876

877

878

879

880

881

882

883

884

885

886

887

888

889

890

891

892

893

894

895

896

897

898

899

900

901

902

903

904

905

906

907

908

909

910

911

912

913

914

915

916

917

918

919

920

921

922

923

924

925

926

927

928

929

930

931

932

933

934

935

936

937

938

939

940

941

942

943

944

945

946

947

948

949

950

951

952

953

954

955

956

957

958

959

960

961

962

963

964

965

966

967

968

969

970

971

972

973

974

975

976

977

978

979

980

981

982

983

984

985

986

987

988

989

990

991

992

993

994

995

996

997

998

999

1000

1001

1002

1003

1004

1005

1006

1007

1008

1009

1010

1011

1012

1013

1014

1015

1016

1017

1018

1019

1020

1021

1022

1023

1024

1025

1026

1027

1028

1029

1030

1031

1032

1033

1034

1035

1036

1037

1038

1039

1040

1041

1042

1043

1044

1045

1046

1047

1048

1049

1050

1051

1052

1053

1054

1055

1056

1057

1058

1059

1060

1061

1062

1063

1064

1065

1066

1067

1068

1069

1070

1071

1072

1073

1074

1075

1076

1077

1078

1079

1080

1081

1082

1083

1084

1085

1086

1087

1088

1089

1090

1091

1092

1093

1094

1095

1096

1097

1098

1099

1100

1101

1102

1103

1104

1105

1106

1107

1108

1109

1110

1111

1112

1113

1114

1115

1116

1117

1118

1119

1120

1121

1122

1123

1124

1125

1126

1127

1128

1129

1130

1131

1132

1133

1134

1135

1136

1137

1138

1139

1140

1141

1142

1143

1144

1145

1146

1147

1148

1149

1150

1151

1152

1153

1154

1155

1156

1157

1158

1159

1160

1161

1162

1163

1164

1165

1166

1167

1168

1169

1170

1171

1172

1173

1174

1175

1176

1177

1178

1179

1180

1181

1182

1183

1184

1185

1186

1187

1188

1189

1190

1191

1192

1193

1194

1195

1196

1197

1198

1199

1200

1201

1202

1203

1204

1205

1206

1207

1208

1209

1210

1211

1212

1213

1214

1215

1216

1217

1218

1219

1220

1221

1222

1223

1224

1225

1226

1227

1228

1229

1230

1231

1232

1233

1234

1235

1236

1237

1238

1239

1240

1241

1 Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender Project options User options Learn

1 x 2 x 3 x 4 x 5 x ...

Send Cancel < >

Target: https://0aa3008404fa412d82219283003200ef.web-security-academy.net HTTP/2

Request

1 GET /my-account?id=viener HTTP/2

2 Host: 0aa3008404fa412d82219283003200ef.web-security-academy.net

3 Cookie: session=Tao0GiUc2VyJyoyOntzOjg6InVsZKJwTWllJztcOjY6IndpZW5lcil7csoIoJhZ0lpblI7YjowO3Ov3d

4 Cache-Control: max-age=0

5 Sec-Ch-Ua: " (Not A:Brand";v="8", "Chromium";v="100"

6 Sec-Ch-Ua-Mobile: ?0

7 Sec-Ch-Ua-Platform: "Windows"

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/100.0.4896.127 Safari/537.36

10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

11 Sec-Fetch-Site: same-origin

12 Sec-Fetch-Mode: navigace

13 Sec-Fetch-User: ?1

14 Sec-Fetch-Dest: document

15 Referer: https://0aa3008404fa412d82219283003200ef.web-security-academy.net/login

16 Accept-Encoding: gzip, deflate

17 Accept-Language: es-ES,es;q=0.9

18

19

Response

1 HTTP/2 200 OK

2 Content-Type: text/html; charset=utf-8

3 Cache-Control: no-cache

4 X-Frame-Options: SAMEORIGIN

5 Content-Length: 3214

6

7 <!DOCTYPE html>

8 <html>

9 <!--LAB_HEAD_START-->

10 <head>

11 <link href="/resources/labheader/css/academyLabHeader.css rel="stylesheet">

12 <link href="/resources/css/labs.css rel="stylesheet">

13 <title>

14 Modifying serialized objects

15 </title>

16 </head>

17 <!--LAB_HEAD_END-->

18 <body>

19 <script src="/resources/labheader/js/labHeader.js">

20 </script>

21 <!--LAB_HEADER_START-->

22 <div id="academyLabHeader">

23 <section class="academyLabBanner">

24 <div class="container">

25 <div class="logo">

26 </div>

27 <div class="title-container">

28 <h2>

29 Modifying serialized objects

30 </h2>

31 <a class="link-back href="

32 https://portswigger.net/web-security/deserialization/exploiting/lab-deseria

33 lization-modifying-serialized-objects">

34 Back to lab description

35 <svg version="1.1 id="layer_1 xmlns="http://www.w3.org/2000/svg"

36 xmlns:xlink="http://www.w3.org/1999/xlink" x="0px y="0px viewBox="0 0 28 30

37 ' enable-background="new 0 0 28 30" xml:space="preserve title="back-arrow"

38 <g>

39 <polygon points="1.4,0 0,1.2 12.6,15 0,28.8 1.4,30 15.1,15">

40 </polygon>

41 <polygon points="14.3,0 12.9,1.2 25.6,15 12.9,28.8 14.3,30 28,15">

42 </polygon>

43 </g>

44 </svg>

45

46 </div>

47 <div class="widgetcontainer-lab-status is-notsolved">

48

49 LAB

50

51 <p>

52 Not solved

53 </p>

54

55

Inspector

Request Attributes 2

Request Query Parameters 1

Request Body Parameters 0

Request Cookies 1

Request Headers 19

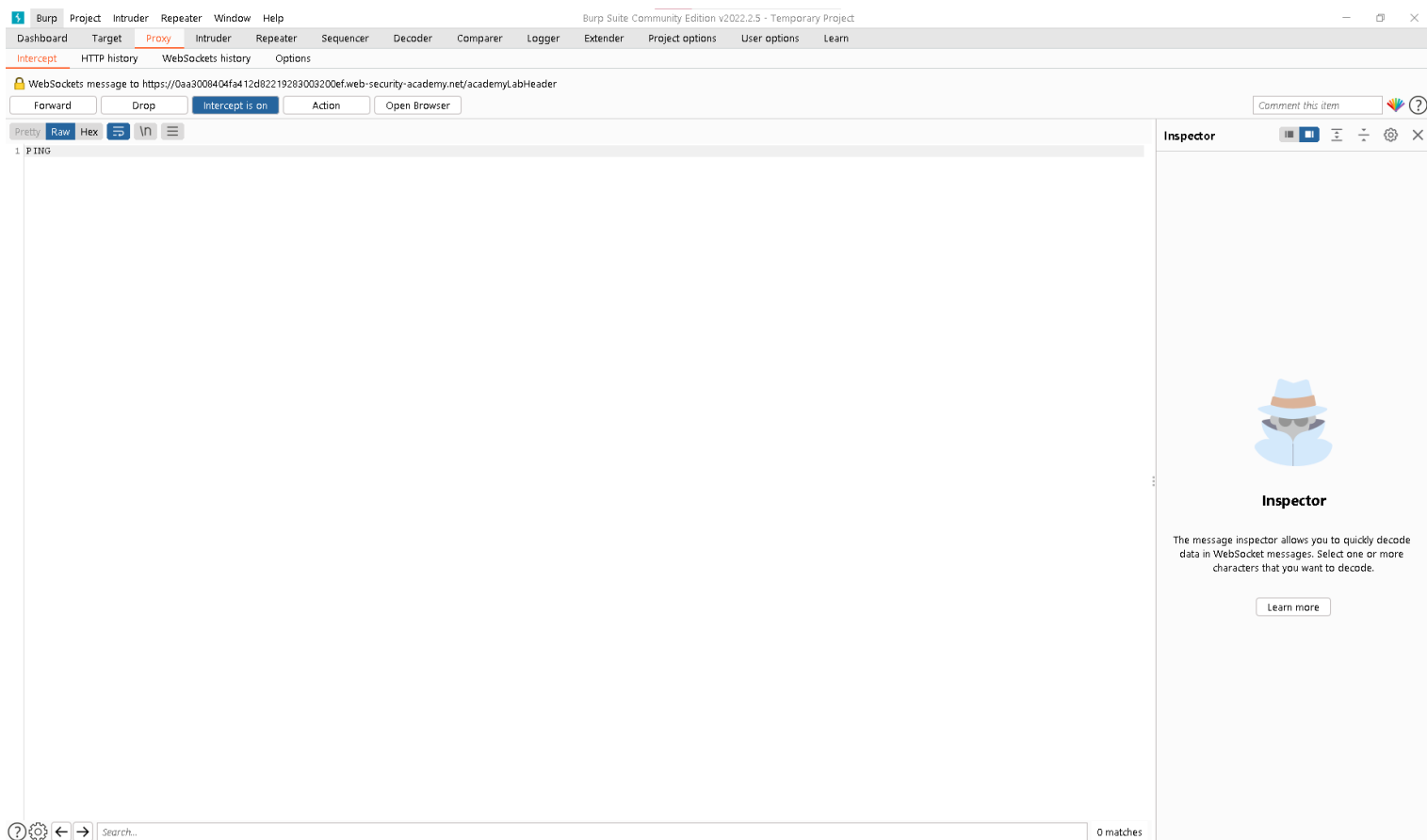
Response Headers 4

0 matches

0 matches

3,347 bytes | 194 millis

Se revisó la información de la solicitud y la respuesta obtenida dentro de Burp Suite.



Se cambió la opción Intercept de Off a On para capturar las peticiones del laboratorio.

Nota:

Durante la realización de la práctica se logró acceder al laboratorio, iniciar sesión, utilizar las herramientas Proxy, HTTP History, Repeater e Intercept de Burp Suite y documentar el proceso realizado. Sin embargo, debido a dificultades técnicas presentadas durante la ejecución del laboratorio y al tiempo disponible por motivos de incapacidad médica, no fue posible completar la fase final correspondiente al acceso al panel de administración y la eliminación del usuario solicitado. Aun así, se presenta la evidencia del trabajo realizado y el mayor avance alcanzado.